REPUBLIQUE DEMOCRATIQUE DU CONGO

ENSEIGNEMENT SUPERIEUR ET UNIVERSITAIRE

UNIVERSITE DE L'ASSOMPTION AU CONGO

« U.A.C »

E-mail : uacuniversite2018@gmail.com

Site : www.uaconline.edu.cd

B.P. 104 **BUTEMBO/Nord-Kivu**

TP DE RECHERCHE D'ÉLÉMENTS DE CRYPTOGRAPHIE ET DE CRYPTANALYSE

Fait Par : KASIKI VIREKERO Alain

Promotion : **M1 SRI**

Titeur : CT Alfred

ANNEE ACADEMMIQUE

2025-2026

0. INTRODUCTION

➢ Définition selon Katz & Lindell (2020)

Selon ces auteurs :

« La cryptographie est la science qui permet de sécuriser l'information et les communications en présence d'adversaires. » (Katz, (2020).)

Ici, l'accent est mis sur le contexte réel : **présence d'attaquants**.

➢ Définition selon Schneier (1996)

Bruce Schneier définit la cryptographie comme :

« L'art et la science de garder les messages sécurisés. »

Une définition simple mais puissante, qui souligne le côté **pratique et stratégique**. (Schneier, 1996)

SUJET 1 : LES FONDEMENTS THEORIQUES ET LEUR MISE EN ŒUVRE

1.1 LE PRINCIPE DE KERCKHOFFS

1.1.1 Énoncé du principe de Kerckhoffs

Le **principe de Kerckhoffs**, formulé en 1883 par le cryptographe néerlandais **Auguste Kerckhoffs**, repose sur six règles fondamentales pour la conception de systèmes cryptographiques sûrs :

1. Le système doit être **pratiquement, sinon théoriquement, incassable**.
2. Il ne doit pas nécessiter le secret, et il doit pouvoir tomber entre les mains de l'ennemi sans inconvénient.
3. La clé doit être **facilement communicable et mémorisable**, sans nécessiter de notes écrites.
4. Le système doit être **adaptable à la communication télégraphique** (aujourd'hui : adaptable aux systèmes numériques).
5. Il doit être **facile à utiliser** et ne pas nécessiter de connaissances complexes.

6. Le système doit être **facile à utiliser en pratique**, même dans des conditions opérationnelles difficiles. (Kerckhoffs, 1883)

1.1.2. Interprétation moderne du principe

Dans le contexte contemporain, ce principe est généralement résumé comme suit :

« La sécurité d'un système ne doit pas reposer sur le secret de son algorithme, mais uniquement sur celui de la clé. »

Cette simplification s'explique par plusieurs raisons :

- Les systèmes modernes sont **publiquement analysés** par la communauté scientifique.
- Les algorithmes sont souvent **standardisés** (ex : AES, RSA).
- Le secret d'un algorithme est difficile à maintenir à long terme (fuites, rétro-ingénierie).

Ainsi, la robustesse d'un système dépend exclusivement de la **protection de la clé**, et non de l'obscurité du mécanisme. (Stallings, 2017)

1.1.3. Importance dans les systèmes cryptographiques modernes

Le principe de Kerckhoffs est fondamental dans la conception des systèmes cryptographiques actuels tels que :

- **AES (Advanced Encryption Standard)**
- **RSA (Rivest-Shamir-Adleman)**

Pourquoi ce principe est essentiel :

1. Audit public et transparence
   les algorithmes ouverts permettent une vérification par des experts indépendants, renforçant la confiance.
2. Résilience face aux attaques
   même si un attaquant connaît parfaitement l'algorithme, il ne peut pas casser le système sans la clé.
3. Interopérabilité et standardisation
   les standards internationaux (nist, iso) reposent sur des algorithmes publics.
4. Sécurité éprouvée

Par exemple :

- AES a été sélectionné après une compétition publique organisée par le NIST.

- RSA repose sur des problèmes mathématiques réputés difficiles (factorisation).

1.1.4. Comparaison avec la « security by obscurity »

Définition

La **security by obscurity** consiste à cacher le fonctionnement interne d'un système pour assurer sa sécurité.

Limites de cette approche :

- ✓ Fragile : une fois le secret révélé, le système devient vulnérable.
- ✓ Non évolutive : difficile à maintenir face aux analyses techniques.
- ✓ Absence de validation scientifique.

1.1.5. Exemple concret d'échec : le système CSS (DVD)

Un exemple emblématique est le système de protection des DVD appelé **Content Scramble System (CSS)** :

- ❖ L'algorithme était **secret** (security by obscurity).
- ❖ En 1999, il a été **cassé** par rétro-ingénierie.
- ❖ Un programme appelé **DeCSS** a permis de décrypter les DVD.

Pourquoi cela a échoué :

- ❖ Le système reposait sur le secret de l'algorithme.
- ❖ Une fois révélé, aucune protection réelle ne subsistait.
- ❖ Les clés étaient faibles et mal protégées.

Cet échec illustre parfaitement la supériorité du principe de Kerckhoffs. (Stevenson, 1999)

Conclusion Partielle

Le principe de Kerckhoffs constitue aujourd'hui un pilier fondamental de la cryptographie moderne. Il impose une séparation claire entre :

- **Algorithme (public)**
- **Clé (secrète)**

Contrairement à la « security by obscurity », cette approche favorise la transparence, la robustesse et la confiance. Les standards modernes comme AES et RSA démontrent que la sécurité durable repose sur des principes ouverts et scientifiquement validés.

2.2 L'ÉCHANGE DE CLES DIFFIE-HELLMAN (DH)

2.2.1. Problème fondamental : la distribution de clés

L'un des problèmes majeurs en cryptographie est la **distribution sécurisée des clés** entre deux parties qui communiquent sur un canal non sécurisé (comme Internet). Avant l'introduction de Diffie-Hellman, les systèmes symétriques exigeaient que les deux parties partagent une clé secrète à l'avance, ce qui posait un défi logistique important, notamment à grande échelle.

Le protocole Diffie-Hellman, introduit par Whitfield Diffie et Martin Hellman en 1976, permet à deux parties d'établir une clé secrète commune **sans l'avoir préalablement partagée**, même en présence d'un adversaire écoutant la communication. (Diffie, 1976)

2.2.2 Fonctionnement du protocole Diffie-Hellman

a) Principe mathématique (logarithme discret)

Le protocole repose sur la difficulté du problème du **logarithme discret**, qui consiste à retrouver un exposant à partir d'une exponentiation modulaire, ce qui est computationnellement difficile.

On choisit :

- ✓ Un nombre premier public ppp
- ✓ Un générateur ggg

Ensuite :

- ✓ Alice choisit un secret aaa, calcule A=gamod pA = g^a \mod pA=gamodp
- ✓ Bob choisit un secret bbb, calcule B=gbmod pB = g^b \mod pB=gbmodp

Ils échangent AAA et BBB, puis calculent :

K=gabmod pK = g^{ab} \mod pK=gabmodp

Nous trouvons que les deux obtiennent la même clé secrète sans jamais transmettre aaa ou bbb. (Menezes, (1996).)

b) Analogie des couleurs (explication intuitive)

Une analogie classique consiste à utiliser des **mélanges de couleurs** :

- Alice et Bob partagent une couleur publique (ex : jaune).
- Alice mélange cette couleur avec sa couleur secrète (ex : rouge).
- Bob mélange la même couleur publique avec sa couleur secrète (ex : bleu).
- Ils échangent les mélanges.
- Ensuite, chacun ajoute sa propre couleur secrète au mélange reçu.

Résultat **:** ils obtiennent **la même couleur finale**, mais un observateur ne peut pas retrouver les couleurs secrètes. (Green, 2016) et (Boneh, 2020)

2.2.3. Vulnérabilité : attaque de type « homme du milieu » (MITM)

Le protocole Diffie-Hellman de base **n'assure pas l'authentification des parties**. Cela ouvre la porte à une attaque de type **Man-in-the-Middle (MITM)**.

Principe de l'attaque :

Un attaquant (Eve) intercepte les échanges :

- Elle remplace la clé publique d'Alice par la sienne auprès de Bob
- Elle remplace la clé publique de Bob par la sienne auprès d'Alice

Résultat :

- Alice partage une clé avec Eve
- Bob partage une clé avec Eve
- Eve peut lire, modifier et retransmettre les messages (Katz J. &., 2020)

2.2.4. Sécurisation dans TLS (Transport Layer Security)

Transport Layer Security est un protocole largement utilisé pour sécuriser les communications sur Internet (HTTPS).

a) Intégration sécurisée de Diffie-Hellman

TLS utilise Diffie-Hellman **avec authentification** :

- Utilisation de **certificats numériques** (PKI)
- Signature des paramètres DH par le serveur
- Vérification de l'identité du serveur par le client

Cela empêche les attaques MITM. (Rescorla, 2018)

b) Diffie-Hellman éphémère (DHE / ECDHE)

TLS utilise souvent :

- DHE (Diffie-Hellman éphémère)
- ECDHE (version sur courbes elliptiques)

<u>Avantage</u> :

- **Perfect Forward Secrecy (PFS)** : même si la clé privée est compromise plus tard, les anciennes communications restent sécurisées.

Conclusion Partielle

L'échange de clés Diffie-Hellman constitue une avancée majeure en cryptographie en permettant l'établissement d'un secret partagé sur un canal non sécurisé. Toutefois, sa version de base présente une vulnérabilité critique face aux attaques MITM en raison de l'absence d'authentification. Les protocoles modernes comme TLS corrigent cette faiblesse en intégrant des mécanismes d'authentification et des variantes éphémères garantissant une sécurité robuste adaptée aux environnements numériques actuels.

SUJET 2 : LA CRYPTOGRAPHIE ASYMETRIQUE ET SES USAGES

3.3 CHIFFREMENT ASYMETRIQUE

3.3.1. Concept de paire de clés (publique / privée)

La cryptographie asymétrique repose sur l'utilisation d'une **paire de clés mathématiquement liées** :

- Une **clé publique**, qui peut être diffusée librement
- Une **clé privée**, qui doit rester strictement secrète

Le principe fondamental est que les données chiffrées avec une clé ne peuvent être déchiffrées qu'avec l'autre. Ainsi, un message chiffré avec la clé publique d'un destinataire ne peut être déchiffré que par sa clé privée, garantissant la **confidentialité**. Inversement, un message signé avec une clé privée peut être vérifié avec la clé publique, assurant **l'authentification et la non-répudiation** . (Stallings, Cryptography and network security: Principles and practice , 2017)

3.3.2. Exemple d'algorithme: RSA

Le système RSA, proposé par Ron Rivest, Adi Shamir et Leonard Adleman en 1977, est l'un des algorithmes asymétriques les plus emblématiques.

- ✓ **Principe mathématique**

RSA repose sur la difficulté de la **factorisation des grands nombres entiers**. Le système fonctionne ainsi :

- On choisit deux grands nombres premiers ppp et qqq
- On calcule n=p×qn = p \times qn=p×q
- La clé publique contient nnn, tandis que la clé privée dépend de la factorisation de nnn

La sécurité de RSA repose sur le fait qu'il est **facile de multiplier deux grands nombres**, mais extrêmement difficile de retrouver ces facteurs à partir du produit lorsque les nombres sont très grands.

Cette asymétrie de complexité constitue ce qu'on appelle une **fonction à sens unique avec trappe** (trapdoor function). (Rivest, 1978) & (Menezes, Handbook of applied cryptography., 1996)

3.3.3. Avantages et inconvénients du chiffrement asymétrique

a) Avantages

1. **Facilité de distribution des clés**
   La clé publique peut être partagée librement sans compromettre la sécurité, ce qui résout le problème de distribution des clés. (Diffie W. &., 1976)
2. **Support de l'authentification et de la signature numérique**
   Permet de garantir l'identité de l'expéditeur et la non-répudiation.
3. **Scalabilité**
   Dans un réseau avec plusieurs utilisateurs, il n'est pas nécessaire de partager une clé secrète différente avec chaque interlocuteur.

b) Inconvénients

1. **Faibles performances**
   Les opérations asymétriques sont beaucoup plus lentes que les opérations symétriques, car elles reposent sur des calculs mathématiques complexes (exponentiation modulaire, etc.) (Stallings, 2017).
2. **Taille des clés élevée**
   Les clés doivent être très longues (ex : 2048 bits pour RSA) pour garantir la sécurité.
3. **Complexité de mise en œuvre**
   Nécessite des infrastructures comme la PKI (Public Key Infrastructure).

3.3.4. Pourquoi combiner asymétrique et symétrique (cas HTTPS)

Dans la pratique, notamment avec HTTPS, on n'utilise pas le chiffrement asymétrique pour chiffrer toutes les données.

a) Raisons principales

1. **Performance**
   Le chiffrement symétrique (comme Advanced Encryptions Standard) est beaucoup plus rapide et adapté aux grandes quantités de données.
2. **Efficacité**
   Les algorithmes asymétriques sont utilisés uniquement pour :
   - Authentifier le serveur
   - Échanger une clé secrète
3. **Sécurité optimisée**
   L'utilisation combinée permet de bénéficier :
   - De la **sécurité de l'asymétrique**
   - De la **rapidité du symétrique**

b) Fonctionnement dans TLS

Dans le protocole Transport Layer Security :

1. Le serveur s'authentifie avec un certificat (asymétrique)
2. Un échange de clé (souvent Diffie-Hellman éphémère) est effectué
3. Une clé de session est générée
4. Les données sont chiffrées avec un algorithme symétrique (AES)

- Ce modèle est appelé **cryptographie hybride**. (Katz J. &., Introduction to modern cryptography., 2020)

Conclusion Partielle

La cryptographie asymétrique constitue un pilier essentiel de la sécurité moderne en permettant la confidentialité, l'authentification et la non-répudiation. Cependant, en raison de ses limites en termes de performance, elle est généralement combinée avec la cryptographie symétrique dans des systèmes hybrides comme TLS. Cette approche permet de tirer parti des avantages des deux techniques, garantissant à la fois sécurité et efficacité dans les communications numériques.

4.4 SIGNATURE NUMERIQUE

4.4.1Principe de la signature numérique

La **signature numérique** est un mécanisme cryptographique basé sur la cryptographie asymétrique qui permet de garantir l'authenticité, l'intégrité et la non-répudiation d'un message. (Stallings, Cryptography and network security: Principles and practice , 2017)

4.4.2. Génération de la signature

Le processus se déroule en plusieurs étapes :

1. Le message est d'abord condensé à l'aide d'une fonction de hachage (ex : SHA-256) pour produire un **empreinte (hash)**
2. Cette empreinte est ensuite **chiffrée avec la clé privée** de l'émetteur
3. Le résultat constitue la **signature numérique**

Cela garantit que seule la personne possédant la clé privée peut produire cette signature

4.4.3. Vérification de la signature

Le destinataire effectue les étapes suivantes :

1. Il déchiffre la signature avec la **clé publique** de l'émetteur
2. Il calcule lui-même le hash du message reçu
3. Il compare les deux empreintes

Si elles sont identiques, la signature est valide

4.4.4 Propriétés de sécurité assurées

- **Intégrité**

Toute modification du message change son empreinte → la signature devient invalide

- **Authentification**

La signature prouve que le message provient bien du détenteur de la clé privée

- **Non-répudiation**

L'émetteur ne peut pas nier avoir signé le message, car lui seul possède la clé privée. (Menezes, Handbook of Applied Cryptography. , 1996)

Ainsi, la signature numérique est l'**inverse fonctionnel du chiffrement asymétrique**
(Katz J. &., Introduction to Modern Cryptography (3rd ed.), 2020)

5.5 CERTIFICAT NUMERIQUE (X.509)

5.5.1 Qu'est-ce qu'un certificat numérique ?

Un **certificat numérique** est un document électronique qui associe une **clé publique à une identité** (personne, serveur, organisation) et qui est signé par une autorité de confiance. (Adams, 2003)

5.5.2 Structure d'un certificat X.509

Un certificat X.509 contient plusieurs champs essentiels :

a. Sujet (Subject)

Identité du propriétaire (nom, organisation, domaine)

b. Clé publique

Clé publique associée au sujet

c. Émetteur (Issuer)

Autorité de certification ayant délivré le certificat

d. Période de validité

- Date de début
- Date d'expiration

e. Numéro de série

Identifiant unique du certificat

f. Signature de la CA

Signature numérique apposée par l'autorité de certification

g. Extensions

Exemples :

- ✓ Usage de la clé
- ✓ Contraintes
- ✓ Alternative DNS (ITU-T., 2019)

5.5.3 Rôle de l'Autorité de Certification (CA)

Une **Autorité de Certification (CA)** est une entité de confiance qui :

- ✓ Vérifie l'identité du demandeur
- ✓ Émet le certificat
- ✓ Signe le certificat avec sa clé privée

- ➢ Elle agit comme un **tiers de confiance** dans les communications sécurisées

5.5.4 Chaîne de confiance

Les certificats sont organisés en **hiérarchie** :

a. Certificat du serveur (end-entity)
b. Certificat intermédiaire
c. Certificat racine (Root CA)

- ➢ Le système vérifie chaque signature jusqu'à une CA racine de confiance préinstallée

5.5.5 Analyse : Faiblesses de la PKI

- ❖ **Compromission d'une CA**

Si une CA est compromise :

- Elle peut émettre de faux certificats
- Toute la chaîne de confiance est menacée

Cas réel : DigiNotar hack
(Clark, 2013)

- ❖ **Confiance excessive**

Les navigateurs font confiance à des centaines de CA :

- Certaines peuvent être moins fiables
- Risque d'abus ou d'erreur

(Kasten, 2013)

❖ **Gestion des révocations**

Les mécanismes comme CRL ou OCSP sont :

- Lents
- Parfois ignorés

Un certificat compromis peut rester valide

4. Problème des certificats "self-signed"

Un certificat **auto-signé** est signé par lui-même :

Avantages

- Simple à créer
- Pas besoin de CA

Inconvénients majeurs

- Aucune garantie d'identité
- Vulnérable aux attaques Man-in-the-Middle

Ils ne sont pas fiables sans distribution sécurisée préalable

Conclusion Partielle

La signature numérique et les certificats X.509 constituent le socle de la sécurité des communications modernes. Toutefois, leur efficacité repose fortement sur la fiabilité de l'infrastructure PKI, dont les failles (notamment les CA compromises et les certificats auto-signés) restent des enjeux critiques.

Bibliographie

Adams, C. &. (2003). *Understanding PKI: Concepts, Standards, and Deployment Considerations.* . Addison-Wesley.

Boneh, D. &. (2020). *A graduate course in applied cryptography.*

Clark, J. &. (2013). *SoK: SSL and HTTPS: Revisiting past challenges and evaluating.*

Diffie, W. &. (1976). *New directions in cryptography.* IEEE Transactions on Information Theory.

Diffie, W. &. (1976). New directions in cryptography. . *IEEE Transactions on Information Theory*, 22(6), 644–654.

Green, M. &. (2016). *The cryptopals crypto challenges.* Cryptopals.

ITU-T. (2019). *Recommendation X.509: Information technology – Open Systems Interconnection – The Directory: Public-key and attribute certificate framewor.*

Kasten, J. e. (2013). *Analysis of the HTTPS certificate ecosystem.* ACM Internet Measurement Conference.

Katz, J. &. (2020). *Introduction to modern cryptography.* CRC Press.

Kerckhoffs, A. (1883). La cryptographie militaire. *Journal des sciences militaires* , 9, 5–38.

Menezes, A. J. (1996). *Handbook of applied cryptography.* CRC Press.

Rescorla, E. (2018). *The Transport Layer Security (TLS) protocol version 1.3.* . RFC.

Rivest, R. L. (1978). A method for obtaining digital signatures and public-key cryptosystems. *Communications of the ACM,* , 21(2), 120–126. .

Schneier, B. (1996). *Applied cryptography* . Wiley.: (2nd ed.). .

Stallings, W. (2017). *Cryptography and network security: Principles and practice* . Pearson. 7th ed.

Stallings, W. (2017). *Cryptography and network security: Principles and practice (7th ed.). Pearson.* (7th ed.). Pearson.

Stevenson, F. A. (1999). *Cryptanalysis of Contents Scrambling System.*

TABLE DES MATIERES

0. INTRODUCTION 1
- Définition selon Katz & Lindell (2020) 2
- Définition selon Schneier (1996) 2

SUJET 1 : LES FONDEMENTS THEORIQUES ET LEUR MISE EN ŒUVRE 2
1.1 LE PRINCIPE DE KERCKHOFFS 2
1.1.1 Énoncé du principe de Kerckhoffs 2
1.1.2. Interprétation moderne du principe 3
1.1.3. Importance dans les systèmes cryptographiques modernes 3
1.1.4. Comparaison avec la « security by obscurity » 4
1.1.5. Exemple concret d'échec : le système CSS (DVD) 4
Conclusion Partielle 4
2.2 L'ÉCHANGE DE CLES DIFFIE-HELLMAN (DH) 5
2.2.1. Problème fondamental : la distribution de clés 5
2.2.2 Fonctionnement du protocole Diffie-Hellman 5
2.2.3. Vulnérabilité : attaque de type « homme du milieu » (MITM) 6
2.2.4. Sécurisation dans TLS (Transport Layer Security) 6
Conclusion Partielle 7
SUJET 2 : LA CRYPTOGRAPHIE ASYMETRIQUE ET SES USAGES 7
3.3 CHIFFREMENT ASYMETRIQUE 7
3.3.1. Concept de paire de clés (publique / privée) 7
3.3.2. Exemple d'algorithme: RSA 7
3.3.3. Avantages et inconvénients du chiffrement asymétrique 8
3.3.4. Pourquoi combiner asymétrique et symétrique (cas HTTPS) 8
a) Raisons principales 8
Conclusion Partielle 9
4.4 SIGNATURE NUMERIQUE 9
4.4.1Principe de la signature numérique 9
4.4.2. Génération de la signature 9
4.4.3. Vérification de la signature 9
4.4.4 Propriétés de sécurité assurées 10
- **Intégrité** 10
- **Authentification** 10
- **Non-répudiation** 10

5.5 CERTIFICAT NUMERIQUE (X.509) 10
5.5.1 Qu'est-ce qu'un certificat numérique ? 10
5.5.2 Structure d'un certificat X.509 10
a. Sujet (Subject) 10
5.5.3 Rôle de l'Autorité de Certification (CA) 11
5.5.4 Chaîne de confiance 11
5.5.5 Analyse : Faiblesses de la PKI 11
4. Problème des certificats "self-signed" 12
Avantages 12
Inconvénients majeurs 12
Conclusion Partielle 12
Bibliographie 13